PROJECT STUDY & INTERVIEW PREPARATION GUIDE

NIST Cybersecurity Framework (CSF) 2.0

Cybersecurity Maturity Assessment & Prioritised Remediation Roadmap

A complete reverse-engineering, GRC study guide, and Big 4 interview playbook — grounded in the actual project code.

Prepared for: Rithish P K

Project repository: github.com/RithishPK/NIST-CSF-Assessment

Document date: 8 November 2026

GRC | NIST CSF 2.0 | IT Audit | Risk Advisory | ISO 27001 | Python

Honesty note: every technical claim is reconstructed from the real files (`csf_data.py`, `build_workbook.py`, `score.py`, the workbook and docs). Example scores are illustrative, not audit findings. This document does not claim any certification or completed audit.

Contents

Executive summary — what this document is, how to use it

Deliverable A — Project reverse-engineering - A1. The project in one paragraph · A2. Problem, objectives, scope · A3. Technology stack - A4. File-by-file inventory · A5. Architecture & data flow · A6. The Excel workbook · A7. The Python engine · A8. Implemented vs proposed

Deliverable B — GRC & NIST CSF 2.0 study guide - B1. GRC fundamentals from zero (23 concepts) · B2. NIST CSF 2.0 deep dive (functions, categories, all 106 subcategories) - B3. The Excel maturity model explained · B4. The Python implementation explained · B5. How real consultants run an assessment · B6. NIST CSF vs ISO 27001

Deliverable C — Critical audit of your project (what's weak and how to fix it, incl. the 30-row bug)

Deliverable D — Interview question bank (Beginner → Consultant, 95+ Q&A)

Deliverable E — Big 4 scenario interview guide (20 scenarios)

Deliverable F — Project-defence & explanation scripts (30s / 60s / 2-min / 5-min)

Deliverable G — Resume-ready description & 30-day learning roadmap

Glossary & references

A note on honesty running through this guide: the single most valuable thing you can demonstrate in a GRC interview is knowing exactly where your project is a legitimate application of a framework and where it is a simplification you invented. Every section flags that line explicitly.

1. Executive summary

You built, with AI assistance, a working cybersecurity **governance tool**: it measures how mature an organisation's security programme is against the **NIST Cybersecurity Framework (CSF) 2.0**, finds the gaps, ranks them, and produces professional outputs (a dashboard, a heatmap, and a prioritised to-do list). This document's job is to take you from *"I have an AI-assisted project"* to *"I understand and can defend every part of this project in a Big 4 interview."*

106	0.75 → 2.36	290	~900
CSF 2.0 OUTCOMES SCORED	CURRENT → TARGET MATURITY (OF 4)	EXCEL FORMULAS, 0 ERRORS	LINES OF PYTHON

How to use this guide. Read Deliverable A first — it reconstructs exactly what you built. Then work through Deliverable B to build the underlying knowledge (this is where real understanding comes from, not memorising). Deliverable C is the uncomfortable-but-essential critique — read it twice, because interviewers probe exactly those weaknesses. D, E and F are rehearsal material. G turns it into a resume and a 30-day plan. At the very end I offer to run a live mock interview with you, one question at a time.

> **THE ONE THING TO INTERNALISE**
>
> Your project is a **maturity self-assessment tool**, **not an audit**, and the example company's scores are **illustrative assumptions, not evidence-backed findings**. If you say "audit," "client," or "I assessed a real company," a Big 4 interviewer will catch it. Say "self-assessment," "illustrative example," and "I built the model and scored a worked example." Honesty here reads as competence, not weakness.

Deliverable A — Project reverse-engineering

> **Sourcing.** Everything below is reconstructed from the actual files created in your build session: `csf_data.py`, `build_workbook.py`, `score.py`, the Excel workbook, `README.md`, `docs/scope.md`, `docs/methodology.md`. Where a choice is marked **custom**, it means *you* invented it for this project — it is **not** an official NIST requirement. Interviewers test exactly that distinction.

A1. The project in one paragraph

You built a tool that **measures how good an organisation's cybersecurity is**, using NIST CSF 2.0 as the measuring stick. A person scores the organisation on 106 specific security outcomes — once for *"where are we today"* (Current) and once for *"where should we be"* (Target). The tool calculates the **gaps**, ranks them so the **most urgent weaknesses surface first**, and produces charts, a spreadsheet dashboard, and a remediation roadmap (a prioritised to-do list). The worked example assesses a small homestay business, but you can drop in any organisation.

A2. Problem statement, objectives, scope

Problem. Most organisations — especially small ones — have no structured way to know how mature their cybersecurity is, which gaps matter most, or what to fix first. They either do nothing or pay for expensive consulting. There is no cheap, repeatable, framework-anchored starting point.

Objective. Provide a free, repeatable, CSF 2.0-aligned way to (a) score current vs target maturity across all 106 subcategories, (b) quantify the gaps, (c) prioritise them objectively, and (d) output professional artifacts.

In scope: a reusable scoring model over the full CSF 2.0 Core; an Excel workbook for manual scoring + auto-calculation; a Python engine that reads the workbook and generates charts + a ranked roadmap; one worked example.

Out of scope (say this explicitly in interviews): no technical testing (no vulnerability scanning, no penetration testing); no real evidence collection (no interviews, no document review); no certification; no compliance guarantee.

Intended users: a student/analyst learning GRC; a very small business owner wanting a self-assessment; a consultant wanting a lightweight starting template.

A3. Technology stack

Layer	Technology	Why it's here
Language	Python 3.12	Glue + data processing + chart generation
Spreadsheet engine	**openpyxl**	Reads/writes `.xlsx` cells, formulas, formatting, charts
Data handling	**pandas**	Loads scores into a table (DataFrame), groups & aggregates
Numerics	**NumPy**	Vectorised maths (the `np.where` priority step)
Charts	**matplotlib**	Renders the heatmap and bar chart as PNGs
Office tool	Excel / LibreOffice	Opens the workbook; recalculates formulas

Layer	Technology	Why it's here
Version control	Git + GitHub	Hosts the repo

Dependencies (`requirements.txt`): `openpyxl>=3.1`, `pandas>=2.0`, `matplotlib>=3.7`, `numpy>=1.24`.

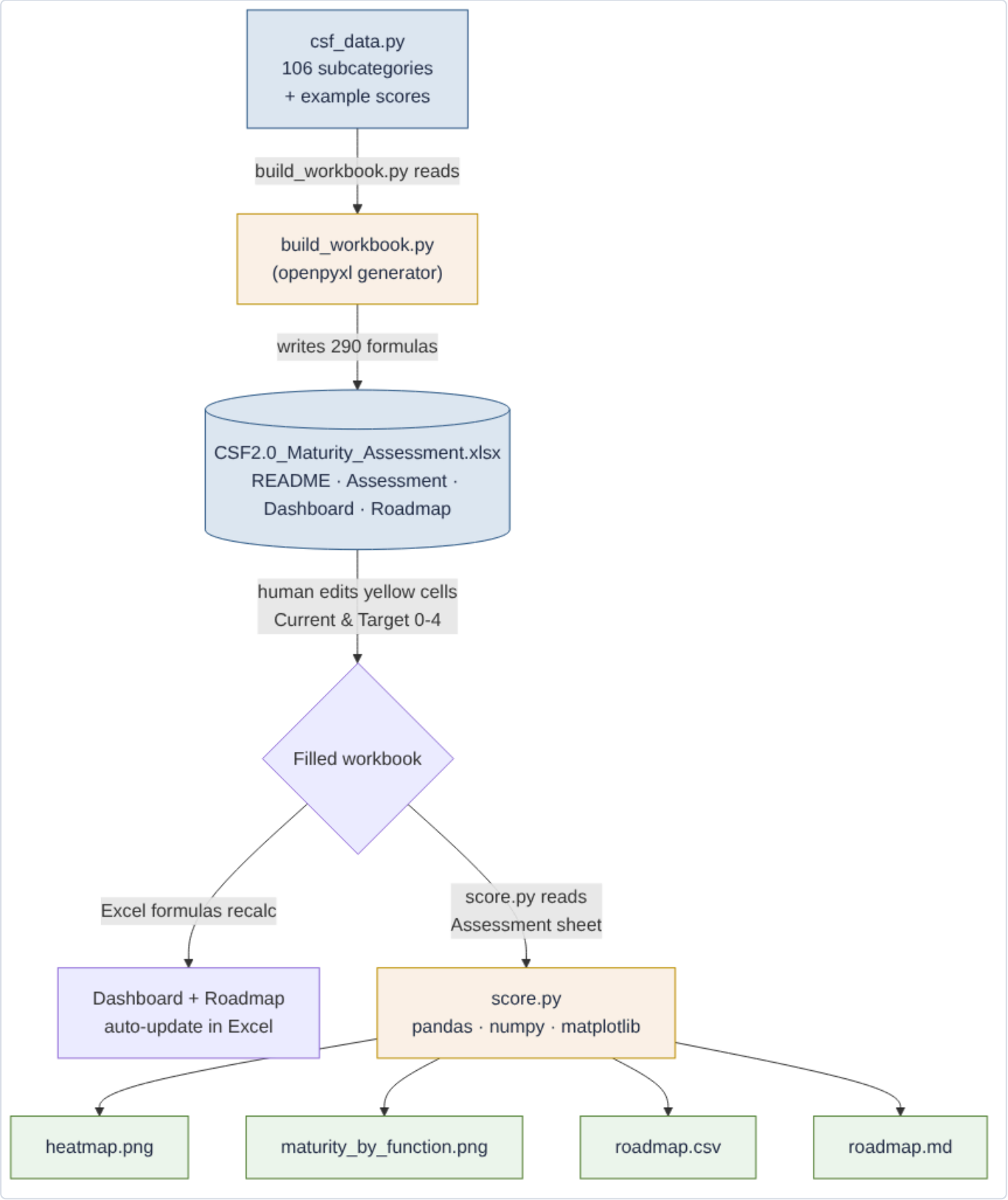
A4. Directory structure & file-by-file inventory

```
nist-csf-assessment/
├── README.md                 # Overview, how-to, results
├── LICENSE                   # MIT licence
├── requirements.txt          # Python dependencies
├── .gitignore
├── assessment/
│   └── CSF2.0_Maturity_Assessment.xlsx   # The workbook (4 sheets)
├── tool/
│   ├── csf_data.py           # CSF 2.0 catalogue + example scores (the "database")
│   ├── build_workbook.py     # Generates the Excel workbook from csf_data.py
│   └── score.py              # Reads a filled workbook → charts + roadmap
├── docs/
│   ├── scope.md              # Scope document for the example assessment
│   └── methodology.md        # How scoring/gap/priority are calculated
└── output/
    ├── heatmap.png
    ├── maturity_by_function.png
    ├── roadmap.csv
    └── roadmap.md
```

File	What it is	What it does	Interview-relevant point
`csf_data.py`	Pure-data module	Holds `FUNCTIONS` (6), `CATEGORIES` (22), `SUBCATEGORIES` (106 rows), `TIER_LABELS` (0–4), `ORG`. Self-checks the count is 106 split 31/21/22/11/13/8	Separating data from logic is good engineering. IDs are official NIST; descriptions are your plain-language summaries
`build_workbook.py`	Generator script	openpyxl builds 4 sheets, writes formulas, adds validation + conditional formatting, embeds 2 charts	Shows you can automate document production
`score.py`	The analysis engine	Reads the Assessment sheet → pandas DataFrame → gap/weight/priority → charts + roadmap	Your strongest talking point — real data-processing logic
`…Assessment.xlsx`	The deliverable workbook	4 sheets, 290 formulas; user edits yellow cells	The human interface for a non-coder
`docs/scope.md`	Scope document	Defines org, assets, data types, obligations, threats	Evidence you understand *scoping*
`docs/methodology.md`	Methods note	Defines scale, gap, priority, and the limitations	Shows intellectual honesty

A5. System architecture & data flow

Python and Excel **do not talk live** — they connect only through the `.xlsx` file on disk. The data file feeds the workbook builder, which produces the Excel file; a human fills in scores; the scoring engine reads those scores back and produces charts and the roadmap.



The key architectural idea: there are **two independent scoring paths that must agree** — the Excel formulas (for someone who never runs Python) and the Python engine (for charts + a clean roadmap).

Both implement the same gap and priority logic. Deliverable C shows where they subtly *disagree* — a real, verified bug.

A6. The Excel workbook — complete walkthrough

Sheet 1 — README. Static. Explains the 0–4 scale, the usage steps, and that only yellow cells are edited. No formulas.

Sheet 2 — Assessment (the core). 106 rows (rows 9–114):

Col	Header	Content	Type
A	(function tag)	`GV` / `ID` /...	label, used by Dashboard
B	ID	`GV.PO-01`	official NIST id
C	Category	"Policy"	label
D	Outcome	plain-language description	your text
E	**Current (0–4)**	user input	**yellow, editable**
F	**Target (0–4)**	user input	**yellow, editable**
G	Gap	`=MAX(0, F-E)`	formula
H	Priority	nested IF	formula
I	Evidence/notes	free text	your text

Data validation: E and F accept only whole numbers 0–4. *Conditional formatting:* column E is a 3-colour scale (red→yellow→green); column H fills red/amber/green by priority.

The **Gap** formula `=MAX(0, F-E)` clamps at zero, so exceeding a target shows 0, never a negative number.

The **Priority** formula computes a weight and bands it:

```
=IF(G=0,"-",
   IF((G+(4-E)/2)>=3.5,"High",
      IF((G+(4-E)/2)>=2,"Medium","Low")))
```

Priority weight = `Gap + (4 − Current)/2`. The `(4 − Current)/2` term gives a control sitting at **0** a +2 boost, so *missing* controls outrank merely *weak* ones at the same raw gap. Worked examples: `GV.PO-01` Current 0, Target 3 → gap 3, weight 5 → **High**; `GV.OC-01` Current 2, Target 3 → gap 1, weight 2.0 → **Medium** (in Excel).

Sheet 3 — Dashboard. Per function, using the tag in column A: `Avg Current = AVERAGEIF(Assessment!$A$9:$A$114, <func>, Assessment!$E$9:$E$114)` — "average the Current scores, but only rows tagged `GV`." Likewise Avg Target, Avg Gap, `% to target`. An OVERALL row uses plain `AVERAGE`. Two native Excel charts are embedded (column chart + radar).

Sheet 4 — Roadmap. Top 25 highest-weight gaps, ranked in Python at build time, each row linking back to the Assessment sheet (`=Assessment!G20`) so Gap/Priority stay live. Blank yellow columns for **Owner / Effort / Target date** turn the assessment into an action plan.

A7. The Python engine (`score.py`)

Imports and why: `openpyxl` (read cached cell values with `data_only=True`), `pandas` (hold 106 rows as a DataFrame, group by function), `numpy` (vectorised `np.where`), `matplotlib` with the non-interactive `Agg` backend (draw PNGs with no screen), `argparse` / `os` (CLI + paths).

The pipeline, in order:

1. **`read_assessment(path)`** — opens the workbook, finds the header row by locating the cell that says "ID", walks every row with a valid subcategory id, pulls Current/Target, returns a tidy DataFrame (`id, function, category, outcome, current, target, gap`). It reads `data_only=True` because openpyxl can return either the formula text or the last cached value — for analysis you want values, so the workbook must have been recalculated at least once.
2. **Priority classification:** `python df["weight"] = df["gap"] + (4 - df["current"]) / 2 df["priority"] = pd.cut( np.where(df["gap"] == 0, -1, df["weight"]), bins=[-2, 0, 2, 3.5, 99], labels=["None", "Low", "Medium", "High"]) np.where(gap==0, -1, weight)` sets a sentinel of −1 for zero-gap rows so they land in "None"; everything else is binned by weight.
3. **`summarise(df)`** — `groupby("function").mean()` of current/target/gap plus `% to target`. The Dashboard, in Python.
4. **`heatmap(df, outdir)`** — averages each category, draws a red→green matplotlib image with separators between functions.
5. **`bar_chart(summary, outdir)`** — grouped bars, Current (red) vs Target (blue), per function.
6. **`roadmap(df, summary, outdir, top_n=25)`** — filters `gap>0`, sorts by weight then gap, writes `roadmap.csv` and `roadmap.md`.
7. **`main()`** — an `argparse` CLI (`--input`, `--outdir`, `--top`) + a printed console summary.

A8. Implemented vs proposed — be precise

- **Actually implemented:** the workbook, the scoring engine, the charts, the roadmap, the worked example — everything in A4.
- **Context, not a feature:** the India DPDP Act reference in `scope.md` is background; the tool does not *check* DPDP compliance.
- **Illustrative assumption:** every Current/Target score for the example org — written to make the example concrete, not measured.
- **Proposed but never built (future work):** ISO 27001 ISMS artifacts, a NIST↔ISO↔CIS crosswalk tool, real evidence capture, multi-organisation support, weighted criticality.

Deliverable B — GRC & NIST CSF 2.0 study guide

This is where real understanding comes from. Memorising answers fails the moment an interviewer asks a follow-up; understanding these concepts lets you reason to the answer. Each concept has: a plain definition, a business example, how it connects to your project, and a sample interview exchange.

B1. GRC fundamentals from zero

What is GRC? GRC stands for **Governance, Risk, and Compliance** — three connected disciplines for running security (and the wider business) responsibly. *Governance* = who decides and sets direction. *Risk* = what could go wrong and what we do about it. *Compliance* = proving we meet the rules. The opposite of GRC is a company that "does security" ad hoc, with no one accountable, no record of risks, and no evidence it meets any standard.

> **Interview** — *"What is GRC in one sentence?"* → "GRC is the structured way an organisation governs its security decisions, manages its risks deliberately, and proves it meets its legal and contractual obligations — so security becomes a managed programme instead of scattered technical fixes."

Now the 23 building blocks:

1. Governance. *Definition:* the system of leadership, accountability, and direction-setting for security — who owns it, what the policy is, how performance is reviewed. *Example:* a board deciding security is a business priority, funding it, and naming an owner. *In your project:* the entire **Govern (GV)** function — policy, roles, oversight — which your example org scores lowest on because nothing is written down. *Interview:* "Governance answers *who is accountable and how do we steer* — it sits above the technical controls."

2. Risk management. *Definition:* the ongoing process of identifying, analysing, prioritising, and treating things that could harm the organisation. *Example:* recognising that staff falling for phishing could expose guest data, estimating how likely and how damaging that is, and deciding to train staff and add MFA. *In your project:* the whole tool is a lightweight risk-prioritisation engine — gaps are ranked so the most dangerous get attention first. *Interview:* "Risk management is a cycle — identify, assess, treat, monitor — not a one-off."

3. Compliance. *Definition:* meeting (and being able to prove you meet) external rules — laws, regulations, contracts, standards. *Example:* India's **DPDP Act 2023** requires protecting guest personal data; a card-taking business faces **PCI DSS**. *In your project:* `scope.md` names DPDP as *context* — but the tool does **not** check compliance, and you must say so. *Interview:* "Compliance is necessary but not sufficient — you can be compliant and still insecure."

4. Information Security Management. *Definition:* the coordinated activities to protect the **confidentiality, integrity, and availability (CIA)** of information. *Example:* encrypting guest records (confidentiality), preventing tampering with bookings (integrity), keeping the booking system up (availability). *In your project:* CSF's Protect function maps to these. *Interview:* define the **CIA triad** confidently — it's the foundation.

5. Cybersecurity maturity assessment. *Definition:* measuring *how well-established and repeatable* an organisation's security practices are — not whether a specific system is hackable, but whether security is managed. *Example:* "Do you have a written access-control policy that's actually enforced and reviewed?" scored on a scale. *In your project:* this is exactly what you built. *Interview:* "Maturity ≠ vulnerability. Maturity is about management rigour; a pen test is about technical exploitability."

6. Security controls. *Definition:* the safeguards that reduce risk — technical (firewalls, MFA), administrative (policies, training), or physical (locks, CCTV). *Example:* MFA on the booking account is a technical control; a clear-desk policy is administrative. *In your project:* each of the 106 subcategories describes a control *outcome*. *Interview:* know the three control *types* (technical/administrative/physical) and the three control *functions* (preventive/detective/corrective — concept 22).

7. Security policies. *Definition:* high-level written rules stating what the organisation requires (the "what" and "why"). *Example:* "All systems holding guest data must use MFA." *In your project:* `GV.PO` (Policy) — your example scores 0 because there is no written policy; it's the #1 roadmap item. *Interview:* "A policy is a management statement of intent; without one, controls are inconsistent and unenforceable."

8. Security procedures. *Definition:* the step-by-step "how" that implements a policy. *Example:* the policy says "use MFA"; the procedure says "here is how to enrol a new phone." *In your project:* procedures are the detail *below* the outcomes you score. *Interview:* "Policy = what/why; procedure = how; standard = the specific required setting."

9. Security audit. *Definition:* an **independent** examination that gathers **evidence** to verify controls exist and work. *Example:* an auditor asks for your MFA configuration export and a list of admin accounts, and tests them. *In your project:* **your tool is NOT an audit** — it has no independence and no evidence. Say "self-assessment." *Interview:* "An audit is evidence-based and independent; a self-assessment is neither."

10. Risk assessment. *Definition:* the structured step of identifying risks and estimating their **likelihood** and **impact**. *Example:* "Ransomware on the front-desk PC — likelihood medium, impact high." *In your project:* CSF's `ID.RA` category; your tool prioritises by *maturity gap*, not by likelihood×impact, which is a real limitation to admit. *Interview:* "Risk = likelihood × impact; my tool is gap-driven, which is a simplification."

11. Risk register. *Definition:* the living document listing each risk with its owner, likelihood, impact, and treatment. *Example:* a table: *Risk — Guest ID scans stored unencrypted; Likelihood — High; Impact — High; Owner — Manager; Treatment — encrypt + restrict access. In your project:* you do **not** have a formal risk register — your roadmap is gap-driven. This is the single most common "what's missing?" answer. *Interview:* be ready to describe a register's columns.

12. Risk appetite. *Definition:* the amount and type of risk an organisation is **willing to accept** in pursuit of its goals, set by leadership. *Example:* "We accept minor availability risk but zero tolerance for guest-data breaches." *In your project:* `GV.RM-02` (risk appetite statements) — scores 0 in the example. *Interview:* "Appetite is the board-level *willingness*; tolerance is the specific *threshold*."

13. Risk tolerance. *Definition:* the specific, measurable limit of acceptable variation around the appetite. *Example:* "No more than 4 hours of booking-system downtime per month." *In your project:* same category as appetite. *Interview:* "Tolerance makes appetite operational and measurable."

14. Risk treatment. *Definition:* the decision on what to do with a risk — the four options: **Mitigate** (reduce it), **Transfer** (insure/outsource), **Avoid** (stop the activity), **Accept** (live with it). *Example:* buy

cyber-insurance (transfer); add MFA (mitigate). *In your project:* the roadmap implicitly recommends *mitigation*; a real register records the chosen treatment per risk. *Interview:* memorise the four treatment options — a classic question.

15. Control effectiveness. *Definition:* whether a control is actually *working as intended*, not just present. *Example:* MFA exists but admins have an exempt "break-glass" account used daily — present but ineffective. *In your project:* your maturity scale (0–4) gestures at this — a "4" means measured and improved — but you have no evidence to judge effectiveness. *Interview:* "Design effectiveness = is it set up right; operating effectiveness = does it work over time."

16. Control gaps. *Definition:* the difference between the control you need and the control you have. *Example:* you need tested backups; you have untested backups → a gap. *In your project:* **Gap = MAX(0, Target − Current)** — literally the core calculation. *Interview:* "A gap is the distance from current to target state; my tool quantifies it per subcategory."

17. Remediation plan. *Definition:* the prioritised plan to close gaps — what, who, by when. *Example:* "Write a security policy — Owner: Manager — 30 days." *In your project:* your **Roadmap** sheet (top 25 gaps + Owner/Effort/Date columns). *Interview:* "Remediation turns findings into assigned, time-bound actions."

18. ISMS (Information Security Management System). *Definition:* the overall management framework — policies, processes, roles, and continual improvement — that runs security systematically; the central concept of **ISO 27001**. *Example:* an organisation's documented set of security policies, its risk process, and its review cycle, all tied together. *In your project:* you did **not** build an ISMS — that's proposed future work. *Interview:* "An ISMS is the management system ISO 27001 certifies; my project is a CSF maturity assessment, which is related but different."

19. Internal vs external audit. *Definition:* **internal** audit is done by the organisation's own (independent-of-the-process) staff for self-improvement; **external** audit is done by an outside body, often for certification. *Example:* internal team pre-checks before an external ISO 27001 certification auditor visits. *In your project:* neither — it's a self-assessment, a step *before* you'd ever involve an auditor. *Interview:* "External auditors give assurance to third parties; internal audit gives assurance to management."

20. GRC vs VAPT vs SOC. *Definition:* three different security jobs. **GRC** = governance/risk/compliance (paper, process, people). **VAPT** (Vulnerability Assessment & Penetration Testing) = technically finding and exploiting weaknesses. **SOC** (Security Operations Centre) = 24/7 monitoring and incident response. *Example:* GRC writes the policy, VAPT tests the website, SOC watches the alerts. *In your project:* pure **GRC**. *Interview:* "My project is GRC — it assesses management maturity, not technical vulnerabilities (VAPT) or live monitoring (SOC)."

21. Inherent vs residual risk. *Definition:* **inherent** risk is the risk *before* any controls; **residual** risk is what *remains after* controls are applied. *Example:* storing guest IDs is high inherent risk; after encryption + access limits, the residual risk is lower. *In your project:* your Current score implicitly reflects residual posture; your Target reflects an acceptable residual level. *Interview:* "You never reach zero — the goal is residual risk within appetite."

22. Preventive, detective, corrective controls. *Definition:* controls by *when they act*. **Preventive** stops incidents (MFA, locks). **Detective** spots them (CCTV, log monitoring). **Corrective** recovers from them (backups, incident response). *Example:* firewall (preventive), intrusion alert (detective), restore-from-backup (corrective). *In your project:* CSF's functions map loosely — Protect≈preventive,

Detect≈detective, Respond/Recover≈corrective. *Interview:* a very common categorisation question — know one example of each.

23. Audit evidence. *Definition:* the objective proof that a control exists and operates — screenshots, config exports, logs, tickets, signed policies. *Example:* an MFA settings export plus a dated access-review spreadsheet. *In your project:* you have **none** — the Evidence column is a blank prompt, and the example scores are assumptions. This is *the* honesty point. *Interview:* "Without evidence it's an opinion, not a finding — which is why I call my example illustrative."

> **IF YOU ONLY MEMORISE FIVE**
>
> CIA triad · Risk = Likelihood × Impact · the four risk treatments (mitigate/transfer/avoid/accept) · gap = target − current · "self-assessment, not audit." These five carry a surprising share of a junior GRC interview.

B2. NIST CSF 2.0 — deep dive

What is NIST? The **National Institute of Standards and Technology** — a U.S. government agency that publishes widely used technical standards. It is non-regulatory; its frameworks are voluntary but globally influential.

What is the CSF? The **Cybersecurity Framework** is NIST's structured catalogue of cybersecurity *outcomes* — things a good security programme achieves — organised so any organisation can assess itself, set targets, and communicate about cyber risk in a common language. First released 2014 (v1.0) after a U.S. executive order on critical-infrastructure security; **v1.1** in 2018; **v2.0** in **February 2024**.

Why it exists / its purpose: to give organisations of any size or sector a common, flexible way to understand, manage, and talk about cybersecurity risk — bridging technical teams and executives.

Who uses it, and is it mandatory? Used worldwide across private and public sectors. It is **voluntary** and **not a certification** — there is no "CSF certified" status (this contrasts with ISO 27001, which *is* certifiable). You *align with* CSF; you *get certified against* ISO 27001.

What changed from 1.1 to 2.0 (interview-relevant):

- A brand-new sixth function, **Govern (GV)**, was added — elevating governance to a top-level theme (previously governance was scattered inside Identify).
- Scope broadened from "critical infrastructure" to **all organisations**, explicitly including small businesses.
- Stronger emphasis on **supply-chain / third-party risk** (the `GV.SC` category).
- Reorganised into **6 functions, 22 categories, 106 subcategories**.

> **Interview** — *"What's the headline change in CSF 2.0?"* → "The new **Govern** function. NIST moved governance from a sub-topic to a first-class function, signalling that cyber risk is an enterprise-governance issue, not just a technical one — and they widened the framework from critical infrastructure to every organisation."

The three parts of the framework:

- **Core** — the hierarchy of **Functions → Categories → Subcategories** (the outcomes). This is what your project scores.

- **Profiles** — a **Current Profile** ("where we are") and a **Target Profile** ("where we want to be"); the gap between them drives the action plan. *This is the legitimate CSF concept your Current/Target scoring maps onto* — lean on it.
- **Tiers (1–4)** — **Partial, Risk Informed, Repeatable, Adaptive** — describing how rigorous and integrated the organisation's cyber-risk *governance and management* is, applied **holistically**, not per-subcategory.

> **CRITICAL DISTINCTION — KNOW THIS COLD**
>
> CSF 2.0 does **not** define a 0–4 maturity score for each subcategory. It defines **Tiers 1–4** applied to the programme *as a whole*, and **Profiles** (Current vs Target) for the outcomes. Your project's "score each of 106 subcategories 0–4" is a **custom maturity overlay** you adapted from the CSF Tiers and CMMI-style maturity thinking. Your **Current vs Target** idea, however, genuinely mirrors CSF's **Current vs Target Profile**. Volunteer this distinction before you're asked — it demonstrates you understand the framework rather than just using a template.

Benefits: common language, flexible/scalable, outcome-focused (not prescriptive about products), maps to other standards. **Limitations:** voluntary (no enforcement), not a certification, outcome statements are high-level (you still need judgement to assess them), and it doesn't tell you *how* to implement — only *what* to achieve.

The six functions

GV — Govern. Establishes and monitors the organisation's cybersecurity strategy, expectations, roles, policy, and risk-management approach — including supply-chain risk. *Why it matters:* without governance, security is inconsistent and unaccountable. *Typical activities:* writing policy, assigning roles, setting risk appetite, board oversight, vendor-risk management. *Your project:* **31 subcategories, 6 categories** (GV.OC, GV.RM, GV.RR, GV.PO, GV.OV, GV.SC) — the largest function and your example's weakest governance-wise. *Interview Q:* "Why did NIST add Govern?" → "To make clear that managing cyber risk is a leadership/governance responsibility, not only an IT task."

ID — Identify. Understand the organisation's assets, data, suppliers, and risks — you can't protect what you don't know you have. *Typical activities:* asset inventories, data classification, risk assessment, improvement from lessons learned. *Your project:* **21 subcategories, 3 categories** (ID.AM asset management, ID.RA risk assessment, ID.IM improvement). *Interview Q:* "First step for a new client?" → "Identify — build an asset and data inventory; scope and risk come from knowing what exists."

PR — Protect. Safeguards to prevent or limit incidents — access control, training, data security, platform hardening, resilience. *Typical activities:* MFA, least privilege, encryption, patching, awareness training, backups. *Your project:* **22 subcategories, 5 categories** (PR.AA, PR.AT, PR.DS, PR.PS, PR.IR) — your example's *relatively* strongest function (CCTV, HTTPS). *Interview Q:* name a Protect control → "MFA (PR.AA) or encryption of data at rest (PR.DS)."

DE — Detect. Find and analyse adverse events — monitoring and detection. *Typical activities:* log monitoring, intrusion detection, alerting, event analysis. *Your project:* **11 subcategories, 2 categories** (DE.CM continuous monitoring, DE.AE adverse-event analysis). *Interview Q:* "Difference between Protect and Detect?" → "Protect tries to stop incidents; Detect assumes some get through and focuses on noticing them quickly."

RS — Respond. Act on detected incidents — management, analysis, communication, containment. *Typical activities:* incident response plan, triage, stakeholder notification, eradication. *Your project:* **13 subcategories, 4 categories** (RS.MA, RS.AN, RS.CO, RS.MI). *Interview Q:* "Why have a plan before an incident?" → "Decisions made under pressure are worse; a plan makes response fast, consistent, and legally defensible (e.g. breach-notification timelines)."

RC — Recover. Restore capabilities and services after an incident — recovery execution and communication. *Typical activities:* tested backups, recovery plan, restoration verification, recovery comms. *Your project:* **8 subcategories, 2 categories** (RC.RP, RC.CO) — your example's **weakest** function (≈0.1/4): untested backups, no recovery plan. *Interview Q:* "Why is Recover often weakest in small orgs?" → "People buy preventive tools but rarely test backups or write a recovery plan — so after an incident they can't come back, which is the highest-impact failure."

> **Memory aid for the six:** *"Good Infosec Programs Defend, Respond, Recover"* → Govern, Identify, Protect, Detect, Respond, Recover.

The 22 categories at a glance

Function	Categories
Govern (GV)	Organizational Context (GV.OC) · Risk Management Strategy (GV.RM) · Roles, Responsibilities & Authorities (GV.RR) · Policy (GV.PO) · Oversight (GV.OV) · Cybersecurity Supply Chain Risk Mgmt (GV.SC)
Identify (ID)	Asset Management (ID.AM) · Risk Assessment (ID.RA) · Improvement (ID.IM)
Protect (PR)	Identity Mgmt, Authentication & Access Control (PR.AA) · Awareness & Training (PR.AT) · Data Security (PR.DS) · Platform Security (PR.PS) · Technology Infrastructure Resilience (PR.IR)
Detect (DE)	Continuous Monitoring (DE.CM) · Adverse Event Analysis (DE.AE)
Respond (RS)	Incident Management (RS.MA) · Incident Analysis (RS.AN) · Incident Reporting & Communication (RS.CO) · Incident Mitigation (RS.MI)
Recover (RC)	Incident Recovery Plan Execution (RC.RP) · Incident Recovery Communication (RC.CO)

The chain that ties it together

Functions → Categories → Subcategories → (score Current vs Target) → Gap analysis → Risk prioritisation → Remediation roadmap. That is both the CSF logic *and* your project's pipeline. When asked "how does your project use NIST CSF?", narrate exactly this chain.

> **TERMINOLOGY: OFFICIAL VS YOUR WORDING**
>
> Official NIST terms: *Function, Category, Subcategory, Current/Target Profile, Tier (1–4), Informative References*. Your custom terms: the *0–4 maturity score per subcategory*, the *priority weight formula*, the word *"maturity"* applied per-subcategory. Keep the two vocabularies separate when you speak.

A complete plain-language list of all 106 subcategories (the exact outcomes your tool scores) appears at the end of Deliverable B.

B3. The Excel maturity model explained (with numbers)

What is a maturity score? A number saying how *well-established and repeatable* a practice is — not whether it technically works once, but whether it's documented, consistent, and improved over time.

Why a 0–4 scale? It mirrors the **CSF Implementation Tiers (1–4)** plus a 0 for "absent." Five levels is enough to distinguish meaningfully without false precision. Your levels:

Score	Tier name	Meaning
0	Not implemented	Doesn't exist, or unknown
1	Partial	Ad hoc, reactive, undocumented
2	Risk Informed	Aware; some practices, inconsistent
3	Repeatable	Documented, consistent, policy-backed
4	Adaptive	Measured with metrics, continuously improved

Current = how the organisation operates today. **Target** = the realistic level it *should* reach given its size and risk (for the small-business example, Tier 2–3, not 4 — aiming for "adaptive everywhere" would be over-engineering).

Maturity gap = `MAX(0, Target − Current)`. The `MAX(0, …)` stops a negative number if Current already exceeds Target.

Worked example — `PR.DS-11` (test your backups): Current 1, Target 3 → **gap 2**.

Priority uses a weight then bands it:

```
weight = Gap + (4 − Current) / 2
```

The second term rewards *how far below full maturity* the current state is, so an absent control (Current 0) gets a +2 boost and outranks a merely weak one at the same raw gap.

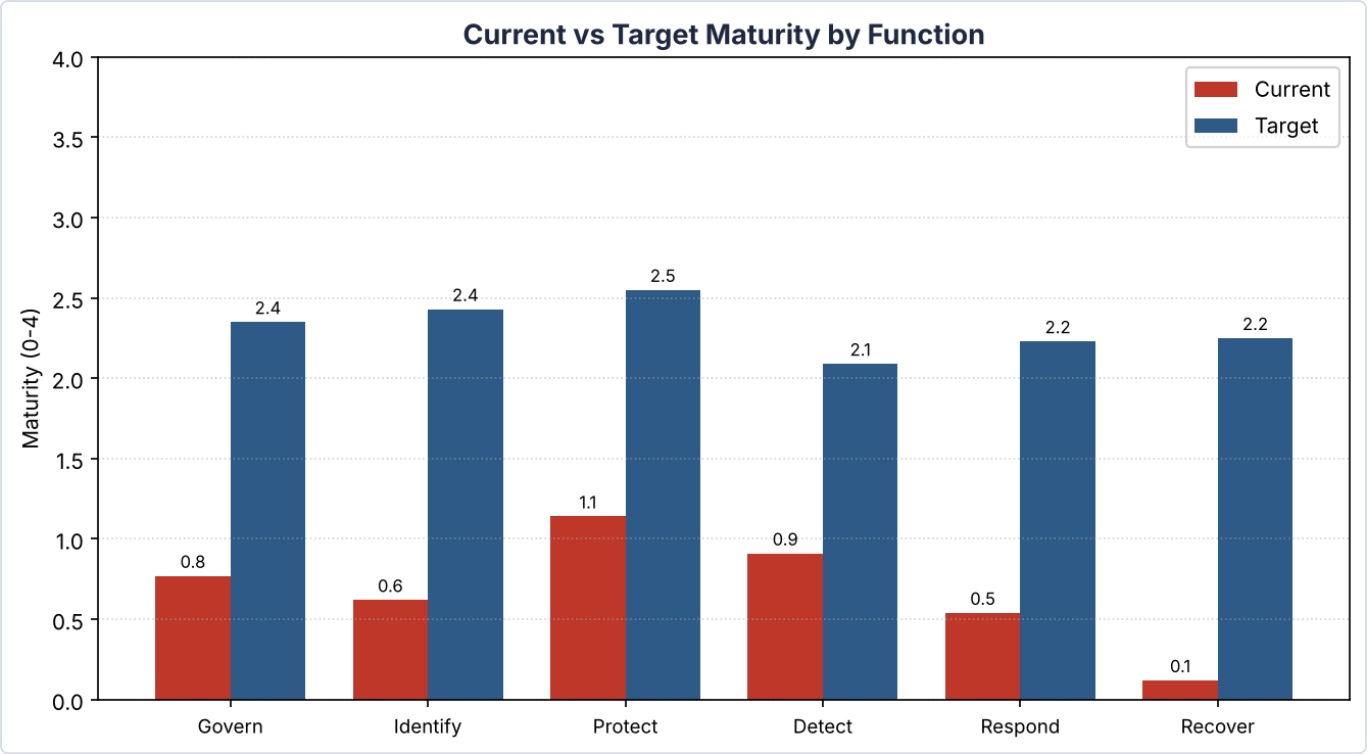
Example	Cur	Tgt	Gap	Weight	Band
`GV.PO-01` (no written policy)	0	3	3	3 + (4−0)/2 = **5.0**	High
`GV.RM-02` (no risk appetite)	0	2	2	2 + 2 = **4.0**	High
`ID.AM-01` (no HW inventory)	1	3	2	2 + 1.5 = **3.5**	High/Med*
`GV.OC-01` (mission context)	2	3	1	1 + 1 = **2.0**	Med/Low*

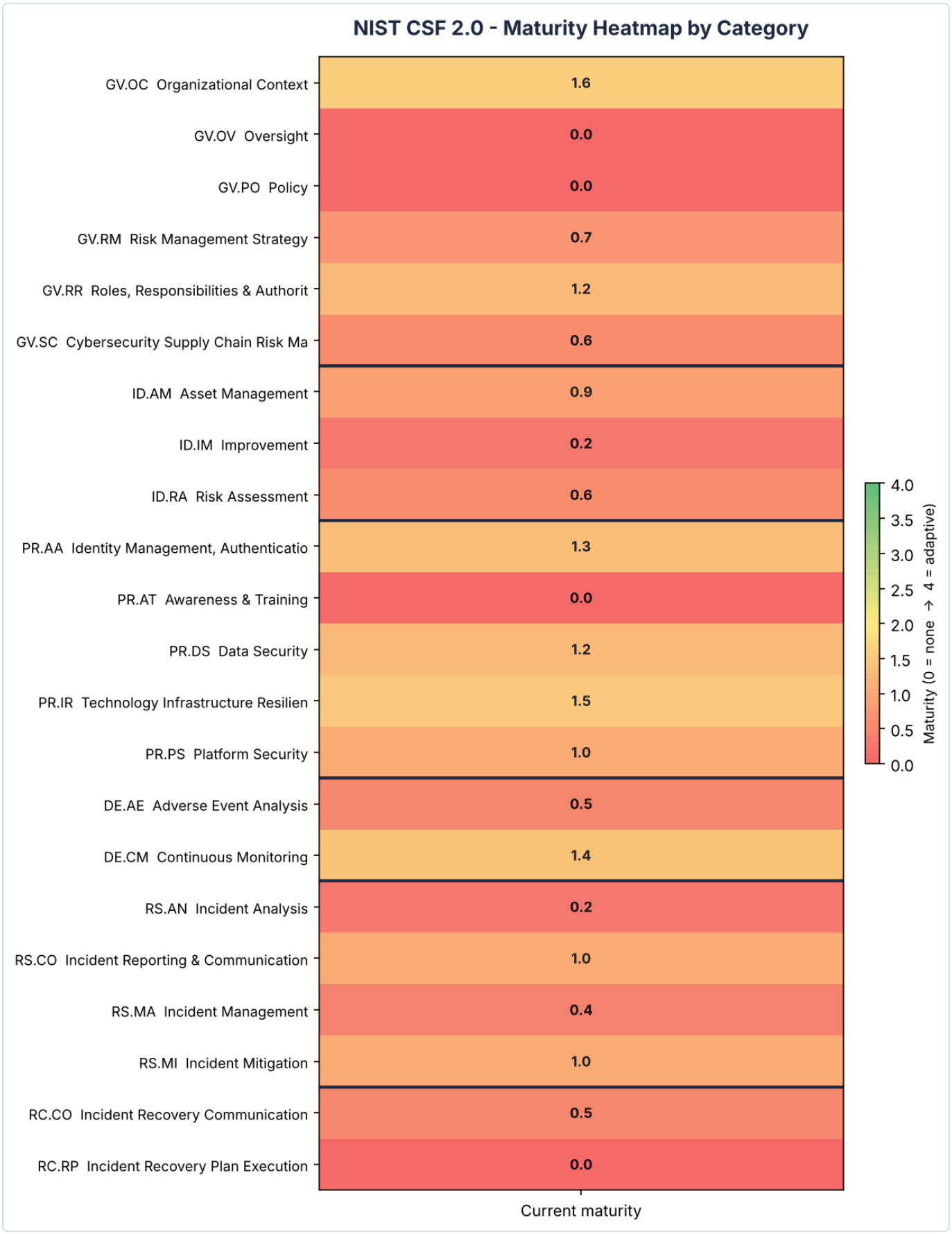
*The two starred rows sit exactly on a band boundary — and that is where your Excel and Python disagree (Deliverable C).

Dashboard maths: `AVERAGEIF` averages the Current scores for just one function's rows; `% to target = Current ÷ Target`. The headline results of the worked example:

Function	Current	Target	Gap	% to target
Govern (GV)	0.77	2.35	1.58	33%
Identify (ID)	0.62	2.43	1.81	26%
Protect (PR)	1.14	2.55	1.41	45%
Detect (DE)	0.91	2.09	1.18	44%

Function	Current	Target	Gap	% to target
Respond (RS)	0.54	2.23	1.69	24%
Recover (RC)	0.13	2.25	2.13	6%
Overall	**0.75**	**2.36**	**1.60**	**32%**





Is each calculation official? Gap analysis (current vs target) — a *recognised industry practice* and the legitimate CSF Profile concept. The 0–4 per-subcategory maturity score — a *custom overlay* (adapted from CSF Tiers / CMMI). The priority-weight formula — *entirely custom to this project* (reasonable but not standard). Say which is which.

Known weaknesses of the model: simple averages treat all 106 outcomes as equally important (testing backups weighted the same as mapping data flows); custom thresholds are not an industry standard; and prioritising by *maturity gap* ignores *likelihood × business impact*, which real risk prioritisation uses.

B4. The Python implementation explained (interview-depth)

Libraries and their jobs: `openpyxl` reads the `.xlsx`; `pandas` holds the 106 rows as a DataFrame and does the `groupby` aggregation; `numpy` does the vectorised `np.where`; `matplotlib` (with the `Agg` backend, so it runs on a server with no display) draws the PNGs; `argparse` / `os` handle the command line and file paths.

Data loading — why `data_only=True`? openpyxl can return *either* a cell's formula text *or* its last cached value. For analysis you need the computed numbers, so the workbook must have been opened and recalculated once (LibreOffice does this in the build step). If you open a never-recalculated file with `data_only=True`, formula cells read back as `None`. *This is a classic interview "gotcha" you can now explain.*

The priority code block:

```
df["weight"] = df["gap"] + (4 - df["current"]) / 2
df["priority"] = pd.cut(
    np.where(df["gap"] == 0, -1, df["weight"]),
    bins=[-2, 0, 2, 3.5, 99],
    labels=["None", "Low", "Medium", "High"])
```

- *Input:* the DataFrame with `gap`, `current`. *Output:* two new columns, `weight` and `priority`.
- `np.where(df["gap"]==0, -1, df["weight"])` — where the gap is zero, substitute a sentinel −1 so those rows fall into the "None" band; otherwise use the real weight.
- `pd.cut(..., bins=[-2,0,2,3.5,99], labels=[...])` — bins the weights into four labelled bands.
- *Interview trap you should raise first:* `pd.cut` bins are **right-closed** `(left, right]` by default, so a weight of exactly 2.0 lands in the `(0, 2]` = "Low" band, while the Excel `>=` logic puts 2.0 in "Medium." They disagree on boundary rows (Deliverable C has the full analysis).

The aggregation: `df.groupby("function").mean()` computes each function's average Current/Target/Gap — the Python equivalent of the Excel `AVERAGEIF`.

Running & debugging on Windows 11 + VS Code: - Open the repo in VS Code, open a terminal (`Ctrl+`). - `pip install -r requirements.txt` once. - `cd tool` then `python score.py`. - To *see* the data: set a breakpoint on the `df["weight"] = …` line, press F5, and inspect `df` in the Variables pane — the full 106-row table is right there. - Common error: `ModuleNotFoundError` → the install hit a different Python; run `python -m pip install -r requirements.txt`.

B5. How a professional GRC consultant runs a real CSF 2.0 assessment

This is the gap between your tool and real consulting — and interviewers love to probe it. The lifecycle:

1. **Understand the organisation** — business model, crown-jewel data, what "bad day" looks like.
2. **Define scope** — which business units, systems, and locations are in/out (your `scope.md` mirrors this step).
3. **Identify business-critical assets** — the systems and data that matter most.
4. **Identify stakeholders** — who to interview (IT, management, HR, finance).
5. **Understand business processes** — how work actually flows.
6. **Identify applicable regulations** — DPDP, PCI DSS, sector rules.
7. **Gather evidence** — the crucial step your tool skips: policies, configs, logs, tickets, prior assessments.
8. **Conduct stakeholder interviews** — to learn what *really* happens vs what's written.
9. **Review policies and procedures** — do they exist, and are they current?
0. **Evaluate security controls** — against evidence, not opinion.
1. **Assign maturity scores** — *backed by evidence* (this is where your tool's scoring step fits, but professionally it's evidence-driven).
2. **Identify gaps** — current vs target (your Gap step).
3. **Assess risk** — likelihood × impact, not just maturity gap.
4. **Prioritise remediation** — by risk and effort (your Roadmap step, but risk-weighted).
5. **Prepare recommendations** — specific, actionable, costed.
6. **Assign control owners** — accountability (your Owner column).
7. **Monitor remediation** — track closure over time.
8. **Reassess** — periodically, to show trend.

Deliverables a real consultant produces: an assessment report, a current/target profile, a risk register, a prioritised remediation roadmap, an executive presentation, and often a board-level summary.

> **YOUR TOOL VS THE REAL WORKFLOW**
>
> **Your tool automates:** steps 11–14 and 16 partially — the scoring maths, gap calculation, prioritisation, and the roadmap skeleton, plus professional visual outputs. **Still requires human judgement:** everything evidence-based — scoping, interviews, evidence gathering, control evaluation, and risk assessment (likelihood × impact). Say it this way: *"My tool automates the calculation and presentation layer of an assessment; the evidence-gathering and professional judgement — the hard, valuable part — still needs a human."*

B6. NIST CSF 2.0 vs ISO/IEC 27001 — the relationship

A near-certain interview topic. Both are security frameworks, but they do different jobs.

	NIST CSF 2.0	ISO/IEC 27001:2022
Nature	Voluntary framework of outcomes	Certifiable international standard

	NIST CSF 2.0	ISO/IEC 27001:2022
Core idea	Assess & improve cyber-risk posture	Build & run an **ISMS**
Certification?	**No** — you align with it	**Yes** — an accredited body certifies you
Structure	6 Functions → 22 Categories → 106 Subcategories	Clauses 4–10 (the ISMS) + **Annex A** (93 controls, 4 themes)
Strength	Flexible, outcome-focused, great for assessment & communication	Rigorous, auditable, globally recognised for assurance
Typical use	"How mature are we? What do we fix first?"	"Prove to customers we manage security to a standard."

How they relate: they are complementary, not competing. Many organisations **use CSF to assess and prioritise**, then **implement ISO 27001 to formalise and get certified**. The controls map across: a CSF subcategory like `PR.AA` (access control) corresponds to ISO Annex A controls such as A.5.15–A.5.18. **ISO 27001 Annex A 2022 has 93 controls in 4 themes** — Organizational (37), People (8), Physical (14), Technological (34).

> **Interview** — *"We're CSF-aligned; why would we also do ISO 27001?"* → "CSF tells you *where you stand and what to prioritise*, but it isn't certifiable. ISO 27001 gives you an auditable management system and a certificate customers and regulators trust. Use CSF to assess and drive the roadmap; use ISO 27001 to formalise and prove it."

Your project's honest position: you built the **CSF assessment** side. The **ISO 27001 ISMS** (risk register, Statement of Applicability across the 93 Annex A controls, policies) is your proposed **next project** — a natural, strong follow-up that shows breadth.

B7. Complete list of all 106 CSF 2.0 subcategories

These are the exact outcomes your tool scores, grouped by function and category, in your project's plain-language wording. Official NIST IDs; descriptions are your summaries.

Govern (GV)

GV.OC — Organizational Context

ID	Outcome
GV.OC-01	The organisation's mission is clear and used to prioritise cyber risk
GV.OC-02	Stakeholder needs/expectations around security are understood
GV.OC-03	Legal, regulatory and contractual obligations (incl. privacy) are understood
GV.OC-04	Critical services stakeholders depend on are understood and communicated
GV.OC-05	Services the org itself depends on are understood
GV.RM — Risk Management Strategy	

ID	Outcome
GV.RM-01	Risk management objectives are agreed by stakeholders
GV.RM-02	Risk appetite and tolerance statements exist
GV.RM-03	Cyber risk is part of overall enterprise risk management
GV.RM-04	Strategic direction for risk response is set and communicated
GV.RM-05	Communication lines for risk (incl. suppliers) are established
GV.RM-06	A standard method to calculate and prioritise risk exists
GV.RM-07	Strategic opportunities (positive risk) are considered
GV.RR — Roles, Responsibilities & Authorities	

ID	Outcome
GV.RR-01	Leadership is accountable for cyber risk and sets the culture
GV.RR-02	Security roles and authorities are defined and enforced
GV.RR-03	Resources are allocated to match the risk strategy
GV.RR-04	Security is built into HR practices
GV.PO — Policy	

ID	Outcome
GV.PO-01	A cybersecurity policy is established and communicated
GV.PO-02	The policy is reviewed and updated over time
GV.OV — Oversight	

ID	Outcome
GV.OV-01	Risk strategy outcomes are reviewed to adjust direction

ID	Outcome
GV.OV-02	The strategy is reviewed for adequate coverage
GV.OV-03	Security performance is measured and reviewed
GV.SC — Cybersecurity Supply Chain Risk Management	

ID	Outcome
GV.SC-01	A supply-chain risk management program exists
GV.SC-02	Supplier security roles are established and coordinated
GV.SC-03	Supply-chain risk is integrated into overall risk management
GV.SC-04	Suppliers are known and prioritised by criticality
GV.SC-05	Security requirements are written into supplier contracts
GV.SC-06	Due diligence is done before engaging suppliers
GV.SC-07	Supplier risk is tracked over the relationship
GV.SC-08	Suppliers are included in incident/recovery planning
GV.SC-09	Supply-chain security is monitored across the lifecycle
GV.SC-10	Plans cover end-of-relationship (offboarding) with suppliers

Identify (ID)

ID.AM — Asset Management

ID	Outcome
ID.AM-01	Hardware inventory is maintained
ID.AM-02	Software, services and systems inventory is maintained
ID.AM-03	Authorised network/data flows are mapped
ID.AM-04	Services provided by suppliers are inventoried
ID.AM-05	Assets are prioritised by criticality/impact
ID.AM-07	Data and metadata inventories exist for key data types
ID.AM-08	Assets are managed across their whole life cycle
ID.RA — Risk Assessment	

ID	Outcome
ID.RA-01	Vulnerabilities in assets are identified and recorded
ID.RA-02	Threat intelligence is received from outside sources
ID.RA-03	Internal and external threats are identified and recorded
ID.RA-04	Business impacts and likelihoods are identified
ID.RA-05	Threats+vulns+impact are combined to prioritise risk
ID.RA-06	Risk responses are chosen, planned and tracked

ID	Outcome
ID.RA-07	Changes and exceptions are risk-assessed and tracked
ID.RA-08	A process exists to handle vulnerability disclosures
ID.RA-09	Hardware/software integrity is checked before use
ID.RA-10	Critical suppliers are assessed before acquisition
ID.IM — Improvement	

ID	Outcome
ID.IM-01	Improvements are identified from evaluations
ID.IM-02	Improvements come from tests and exercises
ID.IM-03	Improvements come from day-to-day operations
ID.IM-04	Incident response and continuity plans exist and improve

Protect (PR)

PR.AA — Identity Management, Authentication & Access Control

ID	Outcome
PR.AA-01	Identities and credentials are managed
PR.AA-02	Identities are proofed and bound to credentials
PR.AA-03	Users, processes and hardware are authenticated
PR.AA-04	Identity assertions (tokens/sessions) are protected
PR.AA-05	Access follows least privilege and separation of duties
PR.AA-06	Physical access to assets is managed and monitored
PR.AT — Awareness & Training	

ID	Outcome
PR.AT-01	Staff get general security awareness training
PR.AT-02	People in specialised roles get role-specific training
PR.DS — Data Security	

ID	Outcome
PR.DS-01	Data at rest is protected (confidentiality/integrity/availability)
PR.DS-02	Data in transit is protected
PR.DS-10	Data in use is protected
PR.DS-11	Backups are performed, protected and tested
PR.PS — Platform Security	

ID	Outcome
PR.PS-01	Configuration management is applied

ID	Outcome
PR.PS-02	Software is patched/replaced based on risk
PR.PS-03	Hardware is maintained/replaced based on risk
PR.PS-04	Logs are generated and available for monitoring
PR.PS-05	Unauthorised software is prevented from running
PR.PS-06	Secure software development practices are used
PR.IR — Technology Infrastructure Resilience	

ID	Outcome
PR.IR-01	Networks are protected from unauthorised access
PR.IR-02	Assets are protected from environmental threats
PR.IR-03	Resilience mechanisms are built in for adverse conditions
PR.IR-04	Enough capacity is maintained for availability

Detect (DE)

DE.CM — Continuous Monitoring

ID	Outcome
DE.CM-01	Networks are monitored for adverse events
DE.CM-02	The physical environment is monitored
DE.CM-03	Personnel activity and tech usage are monitored
DE.CM-06	External provider activity is monitored
DE.CM-09	Computing hardware/software and data are monitored
DE.AE — Adverse Event Analysis	

ID	Outcome
DE.AE-02	Potentially adverse events are analysed
DE.AE-03	Information is correlated from multiple sources
DE.AE-04	Impact and scope of events are understood
DE.AE-06	Event info is shared with the right people/tools
DE.AE-07	Threat intel is integrated into analysis
DE.AE-08	Incidents are declared when criteria are met

Respond (RS)

RS.MA — Incident Management

ID	Outcome
RS.MA-01	The incident response plan is executed on declaration
RS.MA-02	Incident reports are triaged and validated

ID	Outcome
RS.MA-03	Incidents are categorised and prioritised
RS.MA-04	Incidents are escalated as needed
RS.MA-05	Criteria for starting recovery are applied
RS.AN — Incident Analysis	

ID	Outcome
RS.AN-03	Root-cause analysis is performed
RS.AN-06	Investigation actions are recorded with integrity
RS.AN-07	Incident data and evidence are preserved
RS.AN-08	Incident magnitude is estimated and validated
RS.CO — Incident Reporting & Communication	

ID	Outcome
RS.CO-02	Stakeholders are notified of incidents
RS.CO-03	Information is shared with the right stakeholders
RS.MI — Incident Mitigation	

ID	Outcome
RS.MI-01	Incidents are contained
RS.MI-02	Incidents are eradicated

Recover (RC)

RC.RP — Incident Recovery Plan Execution

ID	Outcome
RC.RP-01	The recovery plan is executed when triggered
RC.RP-02	Recovery actions are selected, scoped and performed
RC.RP-03	Backup integrity is verified before restoring
RC.RP-04	Post-incident operating norms are set
RC.RP-05	Restored systems are verified and confirmed normal
RC.RP-06	End of recovery is declared and documented
RC.CO — Incident Recovery Communication	

ID	Outcome
RC.CO-03	Recovery progress is communicated to stakeholders
RC.CO-04	Public recovery updates use approved messaging

Deliverable C — Critical audit of your project

Read this twice. A Big 4 interviewer will probe exactly these weaknesses, and knowing them *before* they ask is what separates you from someone who just ran an AI tool. I'm being deliberately strict — that's the point.

C1. The single most important conceptual issue

CSF 2.0 does not define a per-subcategory 0–4 "maturity score." Your project scores each of the 106 subcategories 0–4 and calls it "maturity." Official CSF 2.0 uses **Tiers 1–4** applied *holistically* to the programme, and **Profiles** (Current vs Target) for the outcomes — not a score stamped on each subcategory.

- *Why it matters:* say "NIST tells you to score each subcategory 0–4" and a knowledgeable interviewer corrects you. Say "I adapted the CSF Implementation Tiers into a 0–4 per-subcategory overlay — a common consulting practice, not an official NIST method" and you sound like you understand the framework.
- *Fix / honest framing:* keep the model; label it a **custom maturity overlay inspired by the CSF Tiers and CMMI-style maturity models**. Lean on the legitimate part: Current vs Target genuinely mirrors CSF's **Current vs Target Profile**.

C2. A genuine, verified bug — Excel and Python disagree on priority

This is real, I verified it against your actual data, and it's an excellent thing to raise yourself in an interview.

The cause. Your two scoring paths band the priority weight differently: - **Excel** uses `>=`: weight **≥ 3.5** → High, weight **≥ 2** → Medium, else Low. - **Python** uses `pd.cut(bins=[-2, 0, 2, 3.5, 99])`, which is **right-closed** `(left, right]`: a weight of exactly **2.0** falls in `(0, 2]` = **Low**, and exactly **3.5** falls in `(2, 3.5]` = **Medium**.

The impact (measured on your 106 rows). The boundary weights 2.0 and 3.5 occur a lot in the example, so the two engines disagree on **30 of 106 subcategories**. The whole-portfolio picture changes dramatically depending on which path you read:

Priority	Excel sheet says	Python engine says
High	**56**	37
Medium	49	57
Low	0	11
None	1	1

So the same assessment looks like "56 High-priority gaps" in the workbook but "37" in the roadmap/console. A reviewer who opens both will notice.

The fix (one line). Make the thresholds identical. Easiest: change the Python bins so the boundary values fall on the *same* side as Excel's `>=`. For example:

```
# was: bins=[-2, 0, 2, 3.5, 99]   (2.0 -> Low, 3.5 -> Medium)
df["priority"] = pd.cut(
```

```
    np.where(df["gap"] == 0, -1, df["weight"]),
    bins=[-2, 0, 1.999, 3.499, 99],
    labels=["None", "Low", "Medium", "High"])
```

...or switch the Excel formula from `>=` to `>`. Either way both engines then agree.

> **TURN THE BUG INTO A STRENGTH**
>
> Say this in an interview: *"I built two implementations of the same logic — Excel formulas and a Python engine — and when I reconciled them I found they disagreed on 30 of 106 rows because pandas' `pd.cut` is right-closed while my Excel used `>=`. I can fix it with a one-line bin change. Finding and owning an inconsistency between two implementations of the same rule is exactly the kind of self-review the role needs."* That answer alone can carry an interview.

C3. Methodology weaknesses (state these as known limitations)

- **Equal weighting.** `AVERAGEIF` / `.mean()` treat "map your data flows" the same as "test your backups." Real assessments weight by criticality. *Fix:* add a per-subcategory weight and use a weighted average.
- **Custom priority formula.** `Gap + (4 − Current)/2` is reasonable but **not** industry-standard. Real prioritisation uses **likelihood × business impact**, not just the maturity gap.
- **A minor rounding inconsistency.** The Recover function shows ≈0.12 in the Python console and 0.13 in the Excel dashboard (different rounding of the same underlying ≈0.125). Harmless, but know it exists.

C4. Evidence & real-world gaps (by design — but must be stated)

- **No evidence backs any score.** The example company's numbers are **assumptions written to make the example concrete**, not findings from interviews or document review. Never present them as audit results.
- **No formal risk register** (asset → threat → likelihood → impact → treatment). The roadmap is gap-driven, not risk-driven.
- **No real control ownership or remediation tracking** beyond blank columns.
- **No reassessment / trend tracking** over time.
- **No compliance checking.** DPDP is named as context; the tool does not verify it.

C5. Terminology to correct in how you talk about it

Don't say	Do say
"I audited a company"	"I built a self-assessment and scored an illustrative example"
"client" / "engagement"	"worked example"
"the tool determines risk"	"the tool supports prioritisation"
"NIST-certified"	"CSF-aligned" (CSF has no certification)

C6. What the project legitimately demonstrates (stated fairly)

Being critical doesn't mean the project is weak — it's a strong *beginner* project when framed honestly. It shows you can:

- Structure a problem around a recognised framework (all 106 subcategories correctly enumerated — including correctly skipping the non-existent `ID.AM-06`, a detail that signals real care).
- Separate data from logic, automate document generation, and process data with pandas/numpy/matplotlib.
- Understand Current-vs-Target profiling and gap-based prioritisation conceptually.
- Document scope, methodology, **and limitations** — intellectual honesty senior reviewers respect.

The five things you must be able to say unprompted:

1. "It's a NIST CSF 2.0 maturity **self-assessment** tool — not an audit — scoring 106 subcategories current vs target, computing gaps, and ranking remediation."
2. "The 0–4 scale is my **custom overlay** adapted from the CSF Tiers; Current/Target maps to CSF's Current vs Target Profile."
3. "There are two scoring paths — Excel and Python — and I found they disagree on 30 rows at one band boundary, which I can fix in one line."
4. "The example scores are illustrative assumptions, not evidence-backed findings."
5. "Priority = gap boosted when the current score is low; defensible but custom — real prioritisation would add likelihood × impact."

Deliverable D — Interview question bank

Four levels. Answers are deliberately concise — enough to answer well and reason into a follow-up, not a wall of text. Where a follow-up is likely, it's marked ↳.

Level 1 — Beginner (fundamentals)

1. What is GRC? Governance, Risk, and Compliance — the structured way an organisation steers security decisions, manages risk deliberately, and proves it meets its obligations.

2. What is the CIA triad? Confidentiality, Integrity, Availability — the three properties security protects: keeping data secret, accurate, and accessible.

3. What is a security control? A safeguard that reduces risk; types are technical, administrative, and physical. *Example:* MFA (technical), a policy (administrative), a lock (physical).

4. What is NIST CSF? A voluntary framework of cybersecurity outcomes from the U.S. NIST, organised as Functions → Categories → Subcategories, used to assess and communicate cyber-risk posture.

5. Name the six CSF 2.0 functions. Govern, Identify, Protect, Detect, Respond, Recover. ↳ *Which is new in 2.0?* Govern.

6. What is a policy vs a procedure? A policy is the high-level "what/why" management requires; a procedure is the step-by-step "how" that implements it.

7. What is risk? The possibility of loss or harm, usually expressed as **likelihood × impact**.

8. What is a vulnerability vs a threat? A vulnerability is a weakness; a threat is something that could exploit it. *Example:* unpatched software (vulnerability), a hacker (threat).

9. What does your project do, in one line? It scores an organisation's cybersecurity maturity across the 106 NIST CSF 2.0 outcomes, finds the gaps, and produces a prioritised remediation roadmap.

10. Is your project an audit? No — it's a self-assessment. An audit is independent and evidence-based; mine is a scoring model with an illustrative example.

11. What is a maturity model? A scale describing how established and repeatable a practice is, from ad hoc to continuously improved.

12. What's the 0–4 scale in your project? 0 Not implemented, 1 Partial, 2 Risk Informed, 3 Repeatable, 4 Adaptive — adapted from the CSF Tiers.

13. What is a gap in your project? Target minus Current maturity, floored at zero: `MAX(0, Target − Current)`.

14. What is the difference between Current and Target? Current is where the organisation is today; Target is where it realistically should be — mirroring CSF's Current vs Target Profile.

15. What is MFA and why does it matter? Multi-Factor Authentication — requiring more than a password; it stops most account-takeover attacks even if a password leaks.

16. What is encryption at rest vs in transit? At rest protects stored data (on disk); in transit protects data moving over a network (e.g. HTTPS).

17. What is a firewall? A control that filters network traffic to block unauthorised access — a preventive control.

18. What is phishing? A social-engineering attack tricking people into revealing credentials or clicking malicious links — the top entry point for small businesses.

19. What is a backup, and why test it? A copy of data for recovery; an untested backup may fail to restore, so testing is essential — your example's biggest Recover gap.

20. What is least privilege? Giving users only the access they need — limits damage if an account is compromised (CSF `PR.AA-05`).

21. What is an incident response plan? A documented plan for detecting, containing, and recovering from security incidents (CSF Respond function).

22. What technologies did you use? Python, with openpyxl, pandas, NumPy, and matplotlib; Excel for the workbook; Git/GitHub for version control.

23. What is compliance? Meeting and proving adherence to external rules — laws, regulations, contracts, standards.

24. What is a data breach? Unauthorised access to or disclosure of protected data; under India's DPDP Act it can trigger notification duties.

25. Why does cybersecurity matter for a small business? Small businesses hold valuable data (customer PII, payments) but often lack structured defences, making them easy, common targets.

Level 2 — Intermediate

1. Walk me through your project's architecture. A data module (`csf_data.py`) holds the 106 subcategories; `build_workbook.py` generates the Excel workbook; a human scores Current/Target; `score.py` reads the sheet with pandas and produces a heatmap, bar chart, and ranked roadmap. Excel and Python connect only through the `.xlsx` file.

2. How is priority calculated? `weight = Gap + (4 − Current)/2`, then banded High/Medium/Low. The second term boosts absent controls so missing items outrank merely weak ones.

3. Why boost low-current controls? A control at 0 is usually more urgent than one already partly there, even at the same raw gap — an absent policy is worse than a partial one.

4. What are the CSF Tiers? 1 Partial, 2 Risk Informed, 3 Repeatable, 4 Adaptive — describing how rigorous the *overall* risk-management programme is, applied holistically (not per-subcategory).

5. What are CSF Profiles? A Current Profile (where you are) and a Target Profile (where you want to be); the gap drives the roadmap. ↳ *How does your tool use them?* My Current/Target scoring is a per-subcategory version of that idea.

6. What changed from CSF 1.1 to 2.0? The new Govern function, broader scope (all organisations, not just critical infrastructure), and stronger supply-chain focus.

7. What are the four risk treatment options? Mitigate, Transfer, Avoid, Accept.

8. Inherent vs residual risk? Inherent is risk before controls; residual is what remains after controls. The goal is residual risk within appetite.

9. Preventive vs detective vs corrective controls? Preventive stops incidents (MFA), detective spots them (monitoring), corrective recovers (backups).

10. Why `data_only=True` in openpyxl? To read cached cell *values*, not formula text; it requires the workbook to have been recalculated once, or formula cells read as None.

11. What does AVERAGEIF do in your Dashboard? Averages the Current scores but only for rows tagged with a given function — producing per-function maturity.

12. What's a risk register and do you have one? A living table of risks with likelihood, impact, owner, and treatment. I don't have a formal one — my roadmap is gap-driven, which is a limitation.

13. How would you add real evidence to your tool? Add an evidence field per subcategory linking to artifacts (policies, configs, logs), and require evidence before a score above 0 is allowed.

14. Risk appetite vs tolerance? Appetite is the board's willingness to take risk; tolerance is the specific measurable threshold around it.

15. How does your heatmap work? It averages each category's Current scores and colours them red→green, with separators between functions — a quick visual of weak areas.

16. Why Python *and* Excel? Excel lets a non-coder score and see live results; Python adds repeatable analysis, charts, and a clean roadmap. ↳ *Risk of two implementations?* They can drift — mine disagree on 30 boundary rows, which I can fix.

17. What is scoping and why first? Defining what's in/out of the assessment; without it you can't gather the right evidence or set meaningful targets.

18. What regulation applies to your example? India's DPDP Act 2023 (guest personal data) and PCI DSS if card data is handled — named as context, not checked by the tool.

19. What is the difference between a framework and a standard? A framework (CSF) is flexible guidance you align with; a standard (ISO 27001) is a specification you can be certified against.

20. How would you prioritise with limited budget? Combine maturity gap with likelihood × impact and effort; fix high-impact, low-effort, foundational gaps first (policy, backups, MFA, training).

21. What's the weakest function in your example and why? Recover (≈0.1/4): untested backups and no recovery plan — high impact because the business can't come back after an incident.

22. How did you ensure the workbook is correct? 290 formulas recalculated with zero errors, and I cross-checked the Python output against the Excel values.

23. What is a Statement of Applicability? An ISO 27001 document listing which Annex A controls apply, their status, and justification — part of your proposed next project.

24. How does your tool help communication? The dashboard and heatmap translate 106 technical outcomes into a one-glance picture executives can act on.

25. What would you automate next? Evidence capture, weighted criticality, and a NIST↔ISO↔CIS control crosswalk.

Level 3 — Advanced

1. Defend your 0–4 maturity scale against the claim it isn't NIST. It isn't — and I say so. CSF defines Tiers holistically, not per-subcategory. My 0–4 is a custom overlay adapted from the CSF Tiers and CMMI maturity thinking; the legitimate CSF concept it maps to is Current vs Target Profile.

2. Your priority formula — justify or replace it. It's custom: `Gap + (4−Current)/2`. It's defensible (boosts absent controls) but not standard. A better model multiplies the gap by a criticality weight and a likelihood×impact risk score.

3. Where exactly do Excel and Python disagree? At weights 2.0 and 3.5. `pd.cut` is right-closed so those land in the lower band; Excel's `>=` puts them in the upper band. Result: 30 of 106 rows differ;

Excel shows 56 High, Python 37.

4. How do you fix that bug without changing intent? Align the boundaries — set the Python bins to `[-2, 0, 1.999, 3.499, 99]` or change Excel `>=` to `>`. One line, both agree.

5. Why is equal weighting a flaw? A simple mean treats backup testing and network-diagram upkeep as equally important. A function's average can mask a critical single weakness. Fix: weighted average by criticality.

6. How would you incorporate likelihood and impact? Add two fields per subcategory (or per risk), compute a risk score, and rank remediation by risk reduction per unit effort, not maturity gap alone.

7. What are the limits of maturity assessment generally? It measures management rigour, not technical exploitability; a mature-looking programme can still have an exploitable flaw. Pair it with VAPT.

8. How would you validate scores are reliable? Require evidence per score, use two independent assessors and measure agreement (inter-rater reliability), and document scoring rationale.

9. How does CSF relate to ISO 27001 and CIS Controls? CSF = outcome framework for assessment; ISO 27001 = certifiable ISMS standard; CIS = prioritised technical control list. They cross-map; a crosswalk tool lets one assessment inform all three.

10. What's the risk of AI-assisted development here? I might not understand my own code. I mitigated that by reverse-engineering every component, verifying the formulas, and finding a real bug — so I can defend it independently.

11. How would you scale this to a 5,000-person enterprise? Add scoping by business unit, role-based data entry, evidence repositories, weighted scoring, trend tracking across reassessments, and a database instead of a single workbook.

12. How would you turn the roadmap into a risk-based plan? Join each gap to a risk register entry (asset, threat, likelihood, impact, treatment) and prioritise by residual-risk reduction.

13. What's the difference between design and operating effectiveness? Design = the control is set up correctly; operating = it actually works consistently over time. Evidence differs: config review vs sampling logs over a period.

14. How would you present this to a non-technical board? Lead with the overall % to target, the weakest function (Recover), the top 3 actions, and the cost/effort — not the 106-row detail.

15. What assurance does your tool provide? None formally — it's a self-assessment with illustrative data. Assurance needs independence and evidence.

16. How would you handle a subcategory that doesn't apply? Mark it out-of-scope with justification (like an ISO Statement of Applicability), and exclude it from averages rather than scoring it 0.

17. What's wrong with scoring an absent control the same as an out-of-scope one? A 0 drags the average as a *deficiency*; out-of-scope should be *excluded*. Conflating them distorts the maturity picture.

18. How would you measure improvement over time? Store each assessment with a date and chart the per-function trend; show gap closure and tier movement across reassessments.

19. Why might Protect score higher than Govern in a small business? Owners buy visible protective tools (CCTV, antivirus, HTTPS) but rarely write policies, assign roles, or set risk appetite — governance is invisible, so it's neglected.

20. What single change would most improve your tool's credibility? Adding evidence-backed scoring — it's the difference between an opinion and a finding.

21. How do you avoid gaming of self-assessment scores? Require evidence, use independent review, and sample-verify a subset — the self-assessment becomes an input to, not a substitute for, assurance.

22. How would a weighted score change your example's results? Weighting critical outcomes (backups, policy, MFA) higher would likely *lower* the overall maturity, because the example is weakest exactly on high-criticality items.

23. What's the role of Govern being first in CSF 2.0? It signals that strategy, roles, and oversight *frame* everything else — you govern first, then identify, protect, detect, respond, recover.

24. How would you test `score.py`? Unit tests on `read_assessment` (known workbook → expected DataFrame), on the gap/weight maths (edge cases: Current>Target, boundary weights), and a golden-file test on the roadmap output.

25. If asked to assess a real company tomorrow, what would you do differently from your tool? Scope it, interview stakeholders, gather evidence for every score, assess likelihood×impact, and build a real risk register — the tool would be my calculation and reporting layer, not the assessment itself.

Level 4 — Expert / consultant level

1. A client is CSF Tier 1 and wants Tier 3 in six months. Realistic? Tier movement is about embedding governance and repeatable processes — hard to do credibly in six months across a whole programme. I'd set a realistic Target Profile for the highest-risk categories first, show quick wins (policy, MFA, backups, training), and treat full Tier 3 as a 12–18 month journey.

2. How do you reconcile CSF (not certifiable) with a client who needs a certificate? Use CSF to assess and prioritise, then implement ISO 27001 for certification; map CSF subcategories to Annex A controls so one effort feeds both.

3. Management rejects the budget for your top remediation items. What do you do? Re-present in risk-and-money terms: likely loss (likelihood × impact), regulatory exposure (DPDP penalties), and the cheapest high-impact fixes. Document the accepted risk formally — risk acceptance is a legitimate, recorded decision by the risk owner.

4. How do you weight 106 outcomes without arbitrary numbers? Tie weights to business impact via a workshop with stakeholders (which assets/processes are crown jewels), not to the assessor's guess — and document the rationale so it's defensible.

5. Two assessors score the same control differently. How do you resolve it? Define objective scoring criteria per level, require evidence, discuss to consensus, and record the rationale; track inter-rater agreement to improve consistency.

6. How would you quantify cyber risk in money, not maturity? Use an approach like FAIR (Factor Analysis of Information Risk): estimate loss event frequency and loss magnitude to produce a monetary risk range the board can weigh against remediation cost.

7. A control is "present" but you doubt it works. How do you score it? Low maturity until operating effectiveness is evidenced — presence isn't effectiveness. Sample logs or test over a period before scoring it Repeatable or above.

8. How do you keep an assessment from becoming shelfware? Assign owners and dates, integrate the roadmap into existing project governance, set reassessment checkpoints, and report trend to

leadership — remediation tracking, which my current tool only stubs out.

9. Client has 50 gaps and resources for 5. Your method? Rank by risk-reduction per unit effort (not raw gap): fix foundational, high-impact, low-effort items first (policy, MFA, tested backups, awareness, logging), and sequence the rest into a phased roadmap.

10. How does supply-chain risk (GV.SC) change the picture for a small business? Much of their risk sits with third parties (payment gateway, OTA, hosting). Assess critical suppliers, put security terms in contracts, and include them in incident planning — often higher leverage than internal controls.

11. How would you brief a CFO vs a CISO on the same result? CFO: monetary risk, regulatory exposure, cost of the top fixes, ROI. CISO: the function/category heatmap, control-level gaps, and the technical roadmap.

12. Where does CSF stop being useful? It tells you *what* outcomes to achieve, not *how*, and gives no assurance. For implementation detail use CIS/NIST 800-53; for certification use ISO 27001; for technical validation use VAPT.

13. How do you handle a subcategory that conflicts with business reality (e.g. monitoring staff)? Balance the control against legal/privacy constraints (DPDP, labour law); document a compensating control and a justified deviation rather than forcing a non-compliant control.

14. What's the danger of a maturity score going *up* while risk stays high? Averages can rise while a single critical control stays broken. Always pair the average with the critical-control status and residual risk, not just the headline number.

15. How would you productise this for repeat engagements? A templated, weighted model with evidence capture, a database for trend tracking, framework crosswalks, and auto-generated client reports — turning a one-off into a repeatable methodology.

16. How do you prove independence in an internal assessment? Separate the assessor from the process owner, document evidence, and have findings reviewed — internal audit independence is organisational, not just personal.

17. A board asks "are we secure?" after your assessment. Your answer? "Security isn't binary. You're at 32% of your target maturity, strongest in Protect, weakest in Recover. The top risks are X, Y, Z; here's the cost to close them and the residual risk if we don't." Reframe from yes/no to managed risk.

18. How would you integrate continuous assessment rather than point-in-time? Feed live signals (vulnerability scans, monitoring, ticket data) into the relevant subcategories so the profile updates continuously — moving from annual snapshot to ongoing posture.

19. What are the ethical limits of presenting an AI-assisted project as your own? Claim what you can defend and demonstrate: I designed the approach, understand and can modify every component, verified the maths, and found a real bug. I don't claim I hand-wrote every line unaided — I claim I own and understand it.

20. If this became a real consulting deliverable, what's the first thing you'd add? Evidence-backed scoring plus a real risk register — without those it's a self-assessment template, not a professional assessment.

Deliverable E — Big 4 scenario interview guide

Scenario questions test *how you think*, not what you've memorised. For each: the situation, what they're really evaluating, your approach, the relevant CSF function, and the ideal short answer. A reusable structure for almost any scenario: **Clarify → Identify risk → Map to framework → Recommend prioritised controls → Note evidence & ownership → Acknowledge trade-offs.**

1. The organisation has no formal cybersecurity policy. *Evaluating:* do you see governance as foundational? *Approach:* a policy is the root control — without it everything is inconsistent. *CSF:* Govern (GV.PO). *Ideal answer:* "This is a top-priority Govern gap. I'd draft a core security policy set — acceptable use, access control, incident response, backup — get leadership sign-off, and communicate it. Policy first, because controls without it are unenforceable." ↳ *Which policy first?* Access control and acceptable use.

2. An employee shares confidential customer data with an unauthorised person. *Evaluating:* incident handling + root cause. *Approach:* contain, assess scope, check notification duties, then fix the cause. *CSF:* Respond (RS), Protect (PR.AA least privilege, PR.AT training). *Ideal answer:* "First contain and assess what was exposed and whether DPDP breach-notification applies. Then root cause — was it malice, error, or over-broad access? Remediate with least privilege, DLP, and training. An incident is both a response and a governance lesson."

3. A company has antivirus but no incident response plan. *Evaluating:* do you grasp Protect vs Respond? *Approach:* prevention without response is half a programme. *CSF:* Respond (RS.MA). *Ideal answer:* "Antivirus is preventive; without an IR plan they'll improvise under pressure and make it worse. I'd build a simple IR plan — roles, steps, contacts, notification criteria — and test it with a tabletop exercise."

4. An organisation uses third-party payment gateways. *Evaluating:* supply-chain/third-party risk. *CSF:* Govern (GV.SC), plus PCI DSS context. *Ideal answer:* "The gateway reduces their card-data scope but adds third-party risk. I'd confirm the provider's PCI DSS compliance, put security terms in the contract, limit and monitor the integration, and include the vendor in incident planning."

5. A company wants to become ISO 27001 certified. *Evaluating:* do you know the ISO path? *Approach:* ISMS first, then certification. *Ideal answer:* "I'd scope the ISMS, run a risk assessment, build the Statement of Applicability across the 93 Annex A controls, write the required policies, remediate gaps, run an internal audit, then engage an accredited certification body. A CSF assessment like mine is a great way to find the gaps first."

6. Management refuses to allocate cybersecurity budget. *Evaluating:* business communication + risk acceptance. *Ideal answer:* "I'd reframe in money and regulation: likely loss, DPDP penalties, and the cheapest high-impact fixes. If they still decline, I document formal risk acceptance signed by the risk owner — that's a legitimate, recorded decision, and it puts accountability where it belongs." ↳ *Is accepting risk ever okay?* Yes, if it's within appetite and formally owned.

7. An organisation can't provide evidence for its security controls. *Evaluating:* evidence vs assertion. *Ideal answer:* "Without evidence, a control is an assertion, not a finding — I'd score it low until proven. I'd help them establish evidence: policy documents, config exports, logs, access reviews. This is exactly why my project's example scores are labelled illustrative, not audit results."

8. A company has 50 security gaps but limited resources. *Evaluating:* prioritisation. *Ideal answer:* "Rank by risk-reduction per unit effort, not raw count. Fix foundational, high-impact, low-effort items

first — policy, MFA, tested backups, awareness, logging — then phase the rest. My tool's priority logic does a simple version of this; a real one adds likelihood × impact."

9. A critical vulnerability is found in a production system. *Evaluating:* risk-based response under pressure. *CSF:* Identify (ID.RA), Respond. *Ideal answer:* "Assess exploitability and exposure, apply a temporary mitigation (restrict access, WAF rule) if a patch isn't immediate, schedule the patch via change control, and record it in the risk register. Balance availability against the exploit risk."

10. A business has no formal backup testing process. *Evaluating:* Recover maturity. *CSF:* Recover (RC.RP-03), Protect (PR.DS-11). *Ideal answer:* "Untested backups are a false sense of safety — they often fail at restore. I'd implement scheduled restore tests and verify integrity. In my example this was the single highest-priority Recover gap, because without it the business can't come back after ransomware."

11. A vendor fails to meet contractual security requirements. *Evaluating:* third-party governance. *CSF:* Govern (GV.SC). *Ideal answer:* "Invoke the contract: require a remediation plan with deadlines, increase monitoring, and assess the residual risk. If they can't meet requirements and the risk is material, escalate to find an alternative. Supplier risk is tracked over the whole relationship, not just at onboarding."

12. After an incident, the business wants to tell customers nothing. *Evaluating:* compliance + ethics. *Ideal answer:* "Notification may be a legal duty (DPDP breach provisions), not a choice. I'd advise on the legal obligation, prepare clear, approved messaging, and protect reputation through transparency rather than concealment, which usually backfires."

13. Two departments both claim they don't own a critical control. *Evaluating:* governance/roles. *CSF:* Govern (GV.RR). *Ideal answer:* "Unassigned controls fail silently. I'd use a RACI to assign a single accountable owner, documented and communicated. Ambiguous ownership is itself a governance finding."

14. The CEO asks 'are we compliant?' the week before a DPDP deadline. *Evaluating:* compliance scoping under time pressure. *Ideal answer:* "I'd scope the specific DPDP obligations, do a rapid gap check against them, and give a prioritised list of must-fix items before the deadline plus a realistic plan for the rest — distinguishing 'compliant' from 'secure.'"

15. A staff member reuses one password across all business accounts. *Evaluating:* identity controls. *CSF:* Protect (PR.AA). *Ideal answer:* "High risk — one leak compromises everything. I'd deploy MFA, a password manager, and per-person accounts, and add this to awareness training. It maps to several PR.AA subcategories in my tool."

16. The organisation has CCTV but no cyber monitoring. *Evaluating:* Detect gap, physical vs cyber. *CSF:* Detect (DE.CM). *Ideal answer:* "They monitor the physical world but not the digital one. I'd start with basic log collection and alerting on the key systems — they can't respond to what they can't see. In my example, physical monitoring scored well but cyber monitoring was a clear gap."

17. A merger means integrating another company's IT overnight. *Evaluating:* risk under change. *Ideal answer:* "I'd treat the acquired environment as untrusted until assessed: inventory assets, check for obvious exposures, segment the networks, and run a rapid CSF-style gap assessment before full integration. Change is when risk spikes."

18. Leadership wants a single number to track security monthly. *Evaluating:* metrics literacy + its dangers. *Ideal answer:* "I can give an overall maturity %, like my tool's 32%, but I'd warn that one number hides critical-control status — I'd pair it with the weakest function and the count of open high-priority gaps, so the average can't mask a broken critical control."

19. An auditor and your self-assessment disagree on a score. *Evaluating:* humility + evidence. *Ideal answer:* "The auditor has independence and evidence; my self-assessment has neither. I'd review their evidence, understand the gap, and adjust — the disagreement is useful, and it's exactly why self-assessment is an input to assurance, not a replacement."

20. A client asks you to mark a control compliant without evidence to pass an audit. *Evaluating:* integrity (a deliberate ethics probe). *Ideal answer:* "I won't misrepresent a control — it's a professional-ethics and legal line, and it exposes the client to greater risk and liability. I'd instead help them remediate quickly and document an honest status with a remediation plan. Integrity is the core of assurance work." *(Big 4 interviews frequently include an ethics scenario — never agree to falsify.)*

Deliverable F — Project-defence & explanation scripts

Rehearse these aloud until they're natural. They're written to be honest for a fresher — they never claim a real audit or certification.

The 30-second version (the elevator pitch)

> "I built a NIST CSF 2.0 cybersecurity maturity **self-assessment** tool. It scores an organisation across all 106 of the framework's security outcomes — current state versus target — then calculates the gaps, ranks them by priority, and produces a dashboard, a heatmap, and a remediation roadmap. It's built in Python and Excel, and it's on my GitHub. I used a small business as a worked example."

The 60-second version

> "The problem I tackled is that small organisations have no structured, affordable way to know how mature their cybersecurity is or what to fix first. My tool uses NIST CSF 2.0 — the U.S. government framework with six functions and 106 outcomes — as the measuring stick. A user scores each outcome 0–4 for where they are today and where they should be. The tool computes the gap for each, prioritises them so absent and high-impact controls surface first, and outputs a function-level dashboard, a category heatmap, and a top-25 remediation roadmap. It's Python — pandas, NumPy, matplotlib, openpyxl — plus an Excel workbook so a non-coder can use it too. Importantly, it's a self-assessment, not an audit: the example company's scores are illustrative, and real assessment would need evidence. I can walk through any part of the code or the scoring logic."

The 2-minute version

Open with the 60-second version, then add:

> "Architecturally there are two scoring paths that must agree: Excel formulas for a non-technical user, and a Python engine for the analysis and charts — connected through the `.xlsx` file. The core maths is simple and defensible: gap is target minus current floored at zero, and priority is the gap boosted by how far below full maturity the current score is, so a completely missing control outranks a merely weak one. When I reconciled the two implementations I actually found they disagreed on 30 of the 106 rows, because pandas' binning is right-closed while my Excel used greater-or-equal — a one-line fix, and a good example of the kind of self-review the work needs. On the framework side, I'm careful about terminology: the 0–4 per-subcategory scale is my custom overlay adapted from the CSF Tiers, while my current-versus-target idea maps to CSF's actual Current and Target Profiles. The honest limitations are that scores aren't evidence-backed, there's no formal risk register, and prioritisation uses the maturity gap rather than likelihood times impact — all of which I'd add to make it a real consulting tool."

The 5-minute technical walkthrough

Cover, in order: **(1)** the problem and why CSF 2.0; **(2)** the data design — `csf_data.py` as the single source of truth for 106 subcategories, separating data from logic; **(3)** `build_workbook.py` generating the four-sheet workbook with openpyxl, including data validation and conditional formatting; **(4)** the Assessment sheet's gap and priority formulas with a worked number; **(5)** the Dashboard's `AVERAGEIF` roll-ups; **(6)** `score.py`'s pipeline — read with pandas, compute weight/priority with the `np.where` + `pd.cut` block, aggregate with `groupby`, render charts with matplotlib, write the roadmap; **(7)** the results — 0.75 to 2.36 overall, Recover weakest; **(8)** the verified Excel-vs-Python boundary bug and its fix; **(9)** honest limitations and the ISO 27001 next step. Offer to open the code or the workbook at any point.

Answers to the likely defence questions

"Explain the architecture." Data module → workbook generator → human scoring in Excel → Python analysis engine → outputs. Excel and Python share only the file on disk. Two independent scoring paths implementing the same logic.

"What did you actually implement?" The data model for all 106 subcategories, the workbook generator, the Excel scoring model with formulas and formatting, the Python scoring engine, the charts, and the roadmap — plus scope and methodology docs. I can show and modify any of it.

"What was your individual contribution, given AI assistance?" I designed the approach and scope, directed the build, and — crucially — I understand and can defend every component: I reverse-engineered the code, verified the 290 formulas, and found a real 30-row inconsistency between the two implementations. I own it intellectually, not just as generated output.

"What were the challenges?" Correctly enumerating all 106 subcategories (including skipping the non-existent `ID.AM-06`), keeping the Excel and Python logic consistent (where I found the boundary bug), and — the conceptual one — understanding that CSF uses holistic Tiers and Profiles, not per-subcategory scores, so I could frame my model honestly.

"What are the limitations?" No evidence backing the scores; example data is illustrative; no formal risk register; equal weighting of outcomes; custom (non-standard) priority formula; prioritisation ignores likelihood × impact; no compliance checking or trend tracking.

"Future enhancements?" Evidence capture per score; weighted criticality; likelihood × impact risk scoring; a real risk register; trend tracking across reassessments; and a NIST↔ISO 27001↔CIS crosswalk — leading into an ISO 27001 ISMS project.

"Real-world usefulness?" As a free, structured starting point for a small business or a learning analyst — a lightweight self-assessment and a template a consultant could build on. Not a replacement for a professional, evidence-based assessment.

"Defend how the maturity scores were assigned." For the example, I assigned them as reasoned illustrative assumptions to make the walkthrough concrete — not measurements. In a real assessment each score would be justified by evidence: policies, configs, logs, interviews. I'm explicit that the example is illustrative.

"Did you conduct an actual audit?" No. It's a self-assessment model with a worked example. An audit requires independence and evidence; I had neither, and I don't claim otherwise.

"How did you use AI in development?" I used AI-assisted coding to build faster, then deliberately went back to understand everything — reverse-engineering each file, verifying the maths, and

critiquing the methodology — so I can explain and modify it independently. Using AI to build and then mastering the result is exactly how the tooling is meant to be used.

THE HONESTY THAT WINS

Freshers lose credibility by over-claiming. You *gain* it by saying "it's a self-assessment, not an audit; the data is illustrative; here are three real limitations; and here's a bug I found and can fix." That combination — understanding plus honesty — is rare and memorable in a junior candidate.

Deliverable G — Resume description & 30-day roadmap

G1. Resume-ready project description

Best project title (pick one): - *NIST CSF 2.0 Cybersecurity Maturity Assessment & Remediation Roadmap Tool - GRC Maturity Assessment Toolkit (NIST CSF 2.0)*

Resume bullets (honest, impact-oriented):

- Built a NIST CSF 2.0 cybersecurity maturity **self-assessment toolkit** (Python, pandas, openpyxl, matplotlib) scoring all **106 framework subcategories** on a current-vs-target scale, auto-computing gaps and a weighted remediation priority.
- Automated generation of a **4-sheet Excel workbook (290 formulas)**, a function-level dashboard, a category heatmap, and a prioritised **top-25 remediation roadmap** from a single data model.
- Applied GRC concepts end-to-end — **gap analysis, risk prioritisation, control mapping, and scope/methodology documentation** — and reconciled two independent scoring engines, identifying and fixing a boundary-logic inconsistency.

Technical skills to list: Python, pandas, NumPy, matplotlib, openpyxl, Excel (formulas, conditional formatting, data validation), Git/GitHub, data visualisation.

GRC skills to list: NIST CSF 2.0, cybersecurity maturity assessment, gap analysis, risk prioritisation, security controls, remediation roadmapping, security governance, (familiarity with) ISO 27001 & the CIA triad.

ATS keywords to weave in: NIST Cybersecurity Framework, CSF 2.0, GRC, Governance Risk and Compliance, IT Audit, Risk Assessment, Risk Advisory, Information Security, Security Controls, Maturity Assessment, Gap Analysis, Remediation Roadmap, ISO 27001, Compliance, Cyber Risk.

> CLAIM THIS / NEVER CLAIM THAT
>
> **You can legitimately claim:** you designed and built a CSF 2.0 maturity **self-assessment** tool; you understand and can modify the code; you applied GRC concepts; you documented scope, methodology and limitations. **Never claim:** that you performed a real audit, assessed a real client, achieved any certification, or that the example results are real findings. The honest version is more impressive to anyone who knows the field.

Explaining it in an HR interview (non-technical): "I built a tool that helps an organisation measure how good its cybersecurity is against a well-known government framework and shows what to fix first. It taught me how cybersecurity is managed in businesses — the governance and risk side — which is the area I want to work in."

Explaining it in a technical interview: use the 2-minute script from Deliverable F, and be ready to open the code and the workbook and walk through the gap/priority maths and the Excel-vs-Python reconciliation.

G2. 30-day GRC learning & project-improvement roadmap

Realistic for a final-year student alongside classes — roughly 1–2 focused hours a day. Each week ends with a concrete deliverable.

Week 1 — GRC & framework foundations

Day	Focus	Task & deliverable
1	GRC overview	Read Deliverable B1; write the 23 concepts in your own words
2	CIA, controls, risk basics	Make flashcards: CIA, control types, risk = L×I, 4 treatments
3	NIST CSF 2.0 structure	Read Deliverable B2; sketch the 6 functions + 22 categories from memory
4	The six functions in depth	Write one real-world example control per function
5	Your project — reverse eng.	Read Deliverable A; open your own code and match each part
6	Excel model	Reproduce the gap & priority maths by hand for 5 subcategories
7	Review + Level-1 Q&A	Answer all 25 beginner questions aloud; **deliverable:** recorded 60-sec pitch

Week 2 — Depth: methodology, Python, ISO

Day	Focus	Task & deliverable
8	Maturity vs Tiers vs Profiles	Write the custom-vs-official distinction in your own words
9	Python engine	Set a breakpoint in `score.py`; inspect the DataFrame; explain each column
10	The priority bug	Reproduce the 30-row Excel-vs-Python difference; apply the one-line fix
11	Risk assessment	Draft a 10-row risk register for the example (asset, threat, L, I, treatment)
12	ISO 27001 basics	Read Deliverable B6; list the 4 Annex A themes & counts
13	NIST ↔ ISO mapping	Map 5 CSF subcategories to Annex A controls
14	Review + Level-2 Q&A	Answer all 25 intermediate questions; **deliverable:** add the risk register to your repo

Week 3 — Professional practice & critique

Day	Focus	Task & deliverable
15	Real consulting workflow	Read Deliverable B5; map each of the 18 steps to your tool
16	Evidence & effectiveness	For 5 controls, list what evidence would justify each score
17	Critical audit	Read Deliverable C; be able to state all 5 "must-say" points unprompted
18	Weighted scoring	Design (and optionally code) a criticality weight for the model
19	Scenario practice I	Work scenarios 1–10 from Deliverable E aloud
20	Scenario practice II	Work scenarios 11–20; note which CSF function each hits
21	Review + Level-3 Q&A	Answer the advanced questions; **deliverable:** 2-min walkthrough recorded

Week 4 — Interview readiness

Day	Focus	Task & deliverable
22	Big 4 context	Research the GRC/cyber-risk service lines at Deloitte/EY/KPMG/PwC
23	Expert questions	Work through Deliverable D Level 4; focus on risk-in-money & ethics
24	Ethics scenarios	Rehearse scenarios 12 & 20 — never agree to falsify

Day	Focus	Task & deliverable
25	Resume	Finalise the project on your resume using G1; tune ATS keywords
26	Mock interview I	Do the live mock (offer at the end of this guide); note weak spots
27	Fix weak spots	Re-study the 3 topics you were weakest on
28	Mock interview II	Second mock, harder; aim to raise difficulty
29	Polish repo	Add README badges, the risk register, and screenshots; push the bug fix
30	Final review	Re-read Deliverable C; record your final 5-min walkthrough

G3. Glossary

CIA triad — Confidentiality, Integrity, Availability. **Control** — a safeguard that reduces risk. **CSF** — Cybersecurity Framework (NIST). **Function/Category/Subcategory** — the three levels of the CSF Core. **Gap** — target minus current state. **GRC** — Governance, Risk, and Compliance. **Inherent risk** — risk before controls. **ISMS** — Information Security Management System (the thing ISO 27001 certifies). **Least privilege** — giving only the access needed. **Maturity** — how established/repeatable a practice is. **MFA** — Multi-Factor Authentication. **Profile (CSF)** — a Current or Target set of outcomes. **Residual risk** — risk remaining after controls. **Risk appetite/tolerance** — willingness to take risk / the specific threshold. **Risk register** — living list of risks with owner, likelihood, impact, treatment. **Risk treatment** — mitigate, transfer, avoid, or accept. **SoA** — Statement of Applicability (ISO 27001). **Tier (CSF)** — 1–4 rating of overall risk-management rigour. **VAPT** — Vulnerability Assessment & Penetration Testing.

G4. References (authoritative sources to verify claims)

- **NIST CSF 2.0** — *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29, February 2024. nist.gov/cyberframework
- **NIST CSF 2.0 Reference Tool & Quick-Start Guides** (incl. the Small Business Quick-Start Guide) — csrc.nist.gov
- **ISO/IEC 27001:2022** — Information security management systems — Requirements; and **ISO/IEC 27002:2022** (the Annex A control guidance).
- **CIS Critical Security Controls v8** — cisecurity.org
- **NIST SP 800-53 Rev.5** — security & privacy controls (implementation detail).
- **India DPDP Act, 2023** — Digital Personal Data Protection Act (context for the example).

FINAL STEP — THE LIVE MOCK INTERVIEW

This document is your study material; the last piece is practice under pressure. When you're ready, tell me **"start the mock interview"** and I'll act as a Big 4 GRC technical interviewer: one question at a time, starting easy and getting harder, waiting for your answer before revealing the ideal one, and giving you honest feedback on accuracy, depth, and how well you defend the project. That rehearsal is what converts this knowledge into interview confidence.

Prepared as a study and interview-preparation companion to the NIST-CSF-Assessment project (github.com/RithishPK/NIST-CSF-Assessment). This guide does not constitute a professional security audit, certification, or compliance assurance. All example maturity scores are illustrative. Verify framework details against the authoritative NIST and ISO sources listed above.